



Report By Shashank M

Topic : VAPT TASK



Sl. No.	Section Title
1	Introduction
2	Theoretical Knowledge
3	VAPT Methodology
4	Security Standards & Compliance
5	Risk Assessment Basics
6	Common Vulnerabilities
7	Documentation Fundamentals
8	Practical Application
9	Setup Testing Environment
10	Vulnerability Scanning
11	Document Findings
12	Practice Risk Assessment
13	Create Basic Reports
14	Conclusion
15	References



Introduction

In today's digital environment, organizations face increasing cyber threats targeting networks, systems, and applications. Identifying vulnerabilities before attackers exploit them is a critical part of maintaining a secure infrastructure. Security assessments and Vulnerability Assessment and Penetration Testing (VAPT) help organizations evaluate their security posture, detect weaknesses, and reduce potential risks.

This report focuses on performing a structured security assessment using open-source tools and industry-standard methodologies. The assessment includes theoretical understanding and practical implementation of vulnerability scanning, risk assessment, and documentation. Tools such as Kali Linux, OpenVAS, Nikto, Metasploitable, and VirtualBox are used to simulate real-world attack scenarios in a controlled lab environment.

The objective of this work is to gain hands-on experience in identifying network and web application vulnerabilities, analyzing their impact using CVSS scoring, and prioritizing risks using a risk matrix. Additionally, the report emphasizes proper documentation practices using tools like Dradis CE and CherryTree, ensuring findings are clearly recorded and presented in a professional manner.

By completing this task, the learner develops foundational skills required for roles in cybersecurity, SOC operations, and penetration testing, while understanding how theoretical security concepts are applied in real-world environments.

Theoretical Knowledge

1. Understanding Security Assessment

Objective:

To learn how to evaluate the security posture of systems using free and open-source tools.

Explanation:

A security assessment involves identifying weaknesses in systems, networks, and applications by following established security frameworks such as **NIST guidelines**. The goal is to understand potential risks before they are exploited.

Types of Security Testing:

- **Vulnerability Assessment:**
Identifies known vulnerabilities using automated tools such as **OpenVAS**, an open-source vulnerability scanner.
- **Penetration Testing:**
Simulates real-world attacks to exploit identified vulnerabilities using tools available in **Kali Linux**, including **Metasploit** and **Nmap**.
- **Compliance Testing:**
Ensures systems align with security standards by using configuration checklists such as **CIS Benchmarks**.



2. VAPT Methodology

Objective:

To follow a structured and systematic approach to vulnerability assessment and penetration testing.

Explanation:

VAPT is conducted in defined phases to ensure consistency and completeness.

Phases:

- **Planning:**
Define scope, targets, and rules of engagement using tools like **Dradis CE** for documentation.
- **Discovery:**
Perform reconnaissance and scanning using **Nmap** for network discovery and **OWASP ZAP** for web application scanning.
- **Attack:**
Exploit discovered vulnerabilities using the **Metasploit Framework**.
- **Reporting:**
Document findings, evidence, and remediation steps using structured reporting templates such as those from **Pentest-Tools**.

How to Learn:

Practice methodologies outlined in the **OWASP Web Security Testing Framework (WSTG)**.

3. Security Standards & Compliance

Objective:

To align security assessments with recognized regulatory and industry standards.

Explanation:

Security standards provide guidelines to protect sensitive information and ensure regulatory compliance.

Key Standards:

- **GDPR** – Data protection and privacy
- **HIPAA** – Healthcare data security
- **ISO/IEC 27001** – Information security management systems

How to Learn:

Use the **OWASP Top 10** to prioritize and understand the most critical web application vulnerabilities.



4. Risk Assessment Basics

Objective:

To prioritize identified vulnerabilities based on their severity and potential impact.

Explanation:

- **CVSS Calculator:**
The **NVD CVSS Calculator** is used to assign numerical severity scores to vulnerabilities.
- **Risk Matrix:**
Vulnerabilities are categorized as **High, Medium, or Low** using a **3×3 likelihood-versusimpact matrix**, typically maintained in **Google Sheets or Excel**.

5. Common Vulnerabilities

Objective:

To identify frequently occurring security flaws using practical lab environments and tools.

Explanation:

- **Network Vulnerabilities:**
Include misconfigurations and unnecessary open ports identified using **Nmap**.
- **Web Vulnerabilities:**
Include **SQL Injection (SQLi)** and **Cross-Site Scripting (XSS)**, practiced using **OWASP Juice Shop**.

How to Learn:

Hands-on practice using intentionally vulnerable platforms such as:

- **Metasploitable** – Vulnerable virtual machine for testing
- **VulnHub** – Collection of vulnerable machines for practical learning

NOTE : Theoretical knowledge focused on understanding security assessments, VAPT methodologies, compliance standards, risk assessment techniques, and common vulnerabilities using open-source tools and industry frameworks.

Practical Application 1.

Setup Testing Environment

Objective:



To create a controlled lab environment for performing vulnerability assessment and penetration testing.

Steps:

- Installed **Kali Linux** as the attacker machine.
- Downloaded **Metasploitable 3**, an intentionally vulnerable virtual machine, from GitHub.
- Configured **VirtualBox** to host multiple virtual machines and enabled network connectivity between Kali Linux and Metasploitable.

2. Vulnerability Scanning

Objective:

To identify security vulnerabilities present in the target system.

Tools Used:

- **OpenVAS (Greenbone Vulnerability Management)** – Integrated in Kali Linux.
- **Nikto** – Web server vulnerability scanner.

Steps:

- Launched OpenVAS using the Greenbone Vulnerability Management interface.
- Configured Metasploitable as a scan target and executed a **Full and Fast** vulnerability scan.
- Analyzed scan results, focusing on **CVSS scores, CVE IDs, affected services, and severity levels**.
- Performed a Nikto scan against the Metasploitable web server to identify web-related vulnerabilities and misconfigurations.

3. Document Findings

Objective:

To systematically record and organize identified vulnerabilities for analysis and reporting.

Tools Used:

- **Google Sheets / Microsoft Excel**



Practical Application :

1. Executive Summary

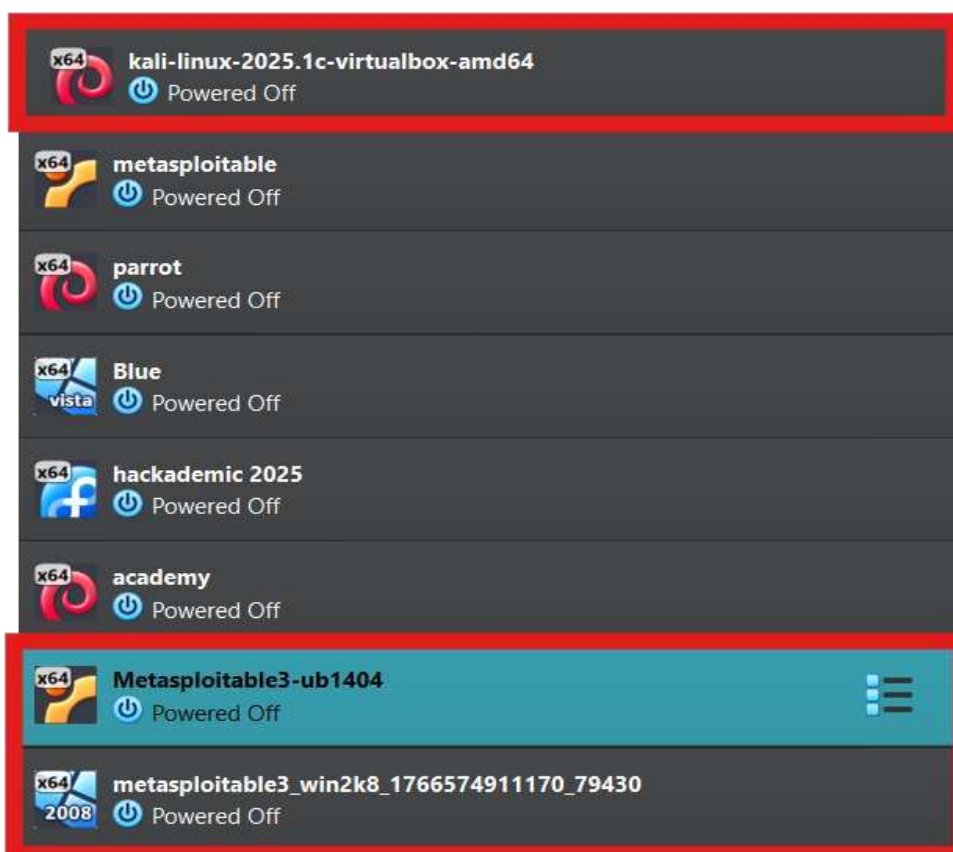
This report presents a vulnerability assessment conducted on a controlled lab environment using open-source security tools. The objective was to identify, analyze, and prioritize security vulnerabilities using industry-standard methodologies. Multiple vulnerabilities of varying severity were identified, including outdated services and weak configurations. Risk assessment was performed using CVSS scoring and a likelihood-versus-impact matrix, and appropriate remediation recommendations were provided.

2. Lab Setup & Environment

A controlled virtual lab environment was configured to safely perform vulnerability assessment and penetration testing activities.

○ Environment Configuration

- Attacker Machine: Kali Linux
- Target Machine: Metasploitable3
- Virtualization Tool: VirtualBox
- Network Mode: Host-Only / Internal Network



Metaspolitable3 configuration:

```
PS C:\Users\Shashank\metasploitable3> bcdedit /set hypervisorlaunchtype off
The boot configuration data store could not be opened.
Access is denied.
PS C:\Users\Shashank\metasploitable3> vagrant up
Bringing machine 'ub1404' up with 'virtualbox' provider...
Bringing machine 'win2k8' up with 'virtualbox' provider...
==> ub1404: Box 'rapid7/metasploitable3-ub1404' could not be found. Attempting to find and install...
ub1404: Box Provider: virtualbox
ub1404: Box Version: >= 0
==> ub1404: Loading metadata for box 'rapid7/metasploitable3-ub1404'
ub1404: URL: https://vagrantcloud.com/api/v2/vagrant/rapid7/metasploitable3-ub1404
==> ub1404: Adding box 'rapid7/metasploitable3-ub1404' (v0.1.12-weekly) for provider: virtualbox
ub1404: Downloading: https://vagrantcloud.com/rapid7/boxes/metasploitable3-ub1404/versions/0.1.12-weekly/providers/virtualbox/unknown/vagrant.box
ub1404:
==> ub1404: Successfully added box 'rapid7/metasploitable3-ub1404' (v0.1.12-weekly) for 'virtualbox'!
==> ub1404: Importing base box 'rapid7/metasploitable3-ub1404'...
==> ub1404: Matching MAC address for NAT networking...
==> ub1404: Checking if box 'rapid7/metasploitable3-ub1404' version '0.1.12-weekly' is up to date...
==> ub1404: Setting the name of the VM: Metasploitable3-ub1404
==> ub1404: Clearing any previously set network interfaces...
==> ub1404: Preparing network interfaces based on configuration...
ub1404: Adapter 1: nat
ub1404: Adapter 2: hostonly
ub1404: This is not an error message; everything may continue to work properly,
ub1404: in which case you may ignore this message.
==> ub1404: Setting hostname...
==> ub1404: Configuring and enabling network interfaces...
==> win2k8: Box 'rapid7/metasploitable3-win2k8' could not be found. Attempting to find and install...
win2k8: Box Provider: virtualbox
win2k8: Box Version: >= 0
==> win2k8: Loading metadata for box 'rapid7/metasploitable3-win2k8'
win2k8: URL: https://vagrantcloud.com/api/v2/vagrant/rapid7/metasploitable3-win2k8
==> win2k8: Adding box 'rapid7/metasploitable3-win2k8' (v0.1.0-weekly) for provider: virtualbox
win2k8: Downloading: https://vagrantcloud.com/rapid7/boxes/metasploitable3-win2k8/versions/0.1.0-weekly/providers/virtualbox/unknown/vagrant.box
win2k8:
==> win2k8: Successfully added box 'rapid7/metasploitable3-win2k8' (v0.1.0-weekly) for 'virtualbox'!
==> win2k8: Importing base box 'rapid7/metasploitable3-win2k8'...
```

Figure1:Metaspolitable3 installation



Network Adapters settings and screenshots below:

Network

Adapter 1: Intel PRO/1000 MT Desktop (NAT Network, 'NatNetwork')

Network

Adapter 1: Intel PRO/1000 MT Desktop (NAT Network, 'NatNetwork')

Adapter 2: Intel PRO/1000 MT Desktop (Host-only Adapter, 'VirtualBox Host-Only Ethernet Adapter #2')

Figure 1: VirtualBox showing Kali Linux and Metasploitable3 virtual machines.

3. Vulnerability Scanning

○ OpenVAS Scanning

OpenVAS was used to perform an automated vulnerability scan against the target system to identify known vulnerabilities and misconfigurations.

- Scan type: Full and Fast
- Target IP :192.168.0.1 (Metasploitable3)
- Scan duration: 5:45



New Target

Name: Metasploitable

Comment:

Hosts:
☒ Manual: 192.168.0.101
☐ From file: [upload icon]

Exclude Hosts:
☒ Manual: [text field]
☐ From file: [upload icon]

Allow simultaneous scanning via multiple IPs:
☒ Yes ☐ No

Port List:
All IANA assigned TCP

Alive Test:
☒ Use Scan Config Default ☐ Consider Hosts as Alive ☐ Custom

Buttons: Cancel, Save



Figure 2: OpenVAS scan configuration

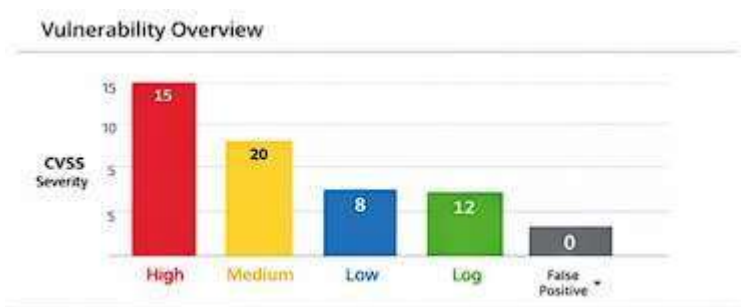


Figure 3: OpenVAS vulnerability results with CVSS scores

○ Nikto Web Server Scanning



Nikto was used to scan the target web server for outdated software, insecure configurations, and known web vulnerabilities.

- **Command used**

nikto -h http://192.168.56.1

```
(kali@kali)-[~]
$ nikto -h http://192.168.0.1
- Nikto v2.5.0

+ Target IP:      192.168.0.1
+ Target Hostname: 192.168.0.1
+ Target Port:    80
+ Start Time:     2025-12-24 07:25:39 (GMT-5)

+ Server: No banner retrieved
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ All CGI directories 'found', use '-C none' to test none
+ 26664 requests: 0 error(s) and 2 item(s) reported on remote host
+ End Time:       2025-12-24 07:28:31 (GMT-5) (172 seconds)

+ 1 host(s) tested
```

Figure 4: Nikto web vulnerability scan results



```
(kali@kali)-[~]
$ nikto -h http://192.168.0.106

- Nikto v2.5.0

+ Target IP: 192.168.0.106
+ Target Hostname: 192.168.0.106
+ Target Port: 80
+ Start Time: 2025-12-24 10:35:35 (GMT-5)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /?PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 12:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2008-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
```

Figure 5: Nikto web vulnerability scan results

4. Documentation of Findings

Identified vulnerabilities were documented using spreadsheets to ensure proper tracking and analysis.

fields:

- IP address
- Port
- Service
- Vulnerability description
- CVSS score
- Risk level



	A	B
1	Column Name	Description
2	IP Address	192.168.0.1
3	Port	
4	Service	samba
5	Vulnerability Name	Remote code execution
6	Vulnerability Description	outdated version
7	CVE ID	CVE-2007-2447
8	CVSS Score	Severity score 10.0
9	Risk Level	High
10	Tool Used	OpenVAS / Nikto
11	Recommended Fix	Patch, upgrade, configuration change
12	Status	Fixed

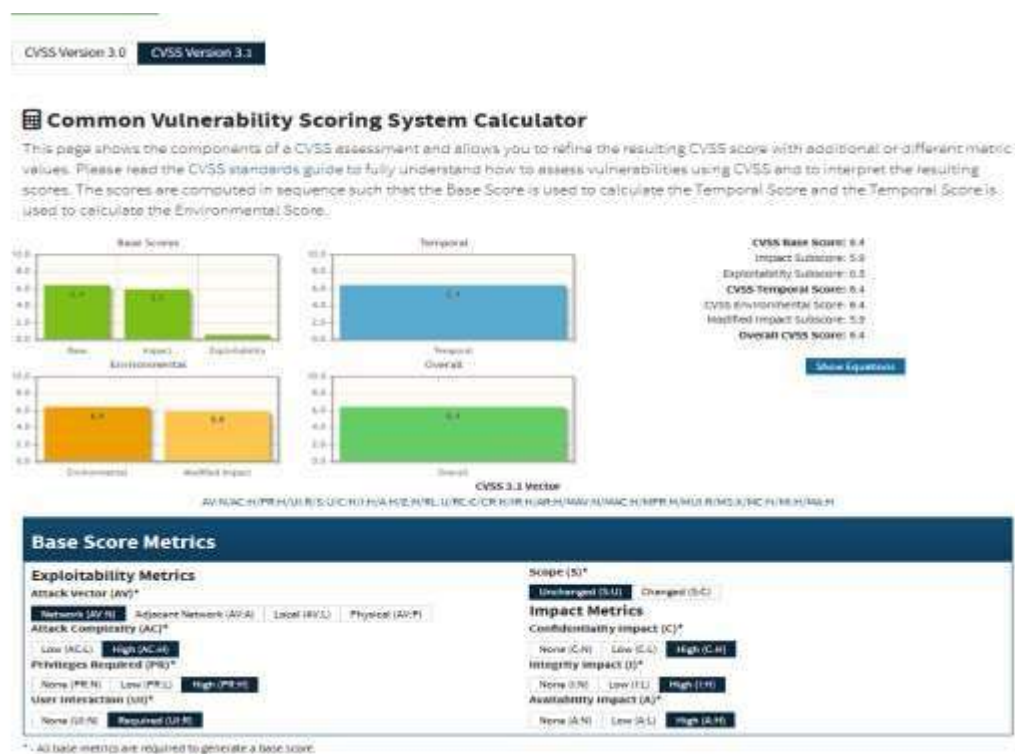
Figure 5: Vulnerability tracking spreadsheet

5. Risk Assessment

○ CVSS Scoring

Each vulnerability was scored using the NVD CVSS v3.1 calculator to determine its severity.

Apache Tomcat outdated → CVSS 8.8 (High)





Temporal Score Metrics	
Exploit Code Maturity (E)	
Not Defined (E:X)	Unproven that exploit exists (E:U) Proof of concept code (E:P) Functional exploit exists (E:F) High (E:H)
Remediation Level (RL)	
Not Defined (RL:X)	Official fix (RL:O) Temporary fix (RL:T) Workaround (RL:W) Unavailable (RL:U)
Report Confidence (RC)	
Not Defined (RC:X)	Unknown (RC:U) Reasonable (RC:R) Confirmed (RC:C)

Environmental Score Metrics		
Exploitability Metrics		
Attack Vector (MAV)		
Not Defined (MAV:X)	Network (MAV:N)	Adjacent Network (MAV:A)
Local (MAV:L)	Physical (MAV:P)	
Attack Complexity (MAC)		
Not Defined (MAC:X)	Low (MAC:L)	High (MAC:H)
Privileges Required (MPR)		
Not Defined (MPR:X)	None (MPR:N)	Low (MPR:L) High (MPR:H)
User Interaction (MUI)		
Not Defined (MUI:X)	None (MUI:N)	Required (MUI:R)
Scope (MS)		
Not Defined (MS:X)	Unchanged (MS:U)	Changed (MS:C)
Impact Metrics		
Confidentiality Impact (MC)		
Not Defined (MC:X)	None (MC:N)	Low (MC:L)
High (MC:H)		
Integrity Impact (MI)		
Not Defined (MI:X)	None (MI:N)	Low (MI:L)
High (MI:H)		
Availability Impact (MA)		
Not Defined (MA:X)	None (MA:N)	Low (MA:L)
High (MA:H)		
Impact Subscore Modifiers		
Confidentiality Requirement (CR)		
Not Defined (CR:X)	Low (CR:L)	
Medium (CR:M)	High (CR:H)	
Integrity Requirement (IR)		
Not Defined (IR:X)	Low (IR:L)	Medium (IR:M)
High (IR:H)		
Availability Requirement (AR)		
Not Defined (AR:X)	Low (AR:L)	
Medium (AR:M)	High (AR:H)	

Figure 6: CVSS v3.1 score calculation

○ Risk Matrix Prioritization

Metric	Value
CVSS Version	3.1
Base Score	8.8 (Critical)
Attack Vector	Network
Attack Complexity	Low
Privileges Required	None
User Interaction	None

Risk Rating (3×3 Matrix)

Factor	Level
Likelihood	High
Impact	High
Risk Level	Critical
Risk prioritization using 3×3 matrix data provided above	

6. Remediation Recommendations



Vulnerability	Risk	Recommendation
Outdated Tomcat	Critical	Upgrade to latest version
Weak SSH Ciphers	Medium	Disable weak algorithms

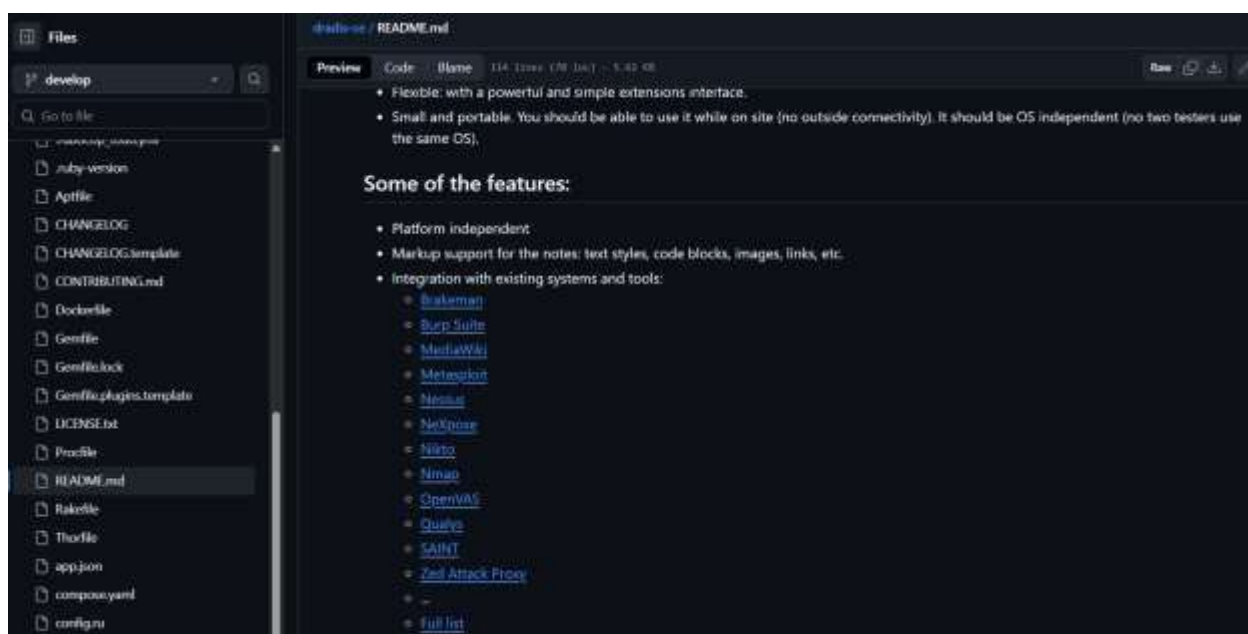
Dradis CE (Collaborative Reporting Tool)

Dradis Community Edition (CE) was used to centrally manage assessment findings, collaborate on documentation, and generate structured reports.

In github gone through the repository for additional information and know how to clone to CLI

Description

- Central repository for vulnerabilities
- Supports team collaboration
- Allows mapping findings to standards
- Exports reports in structured formats



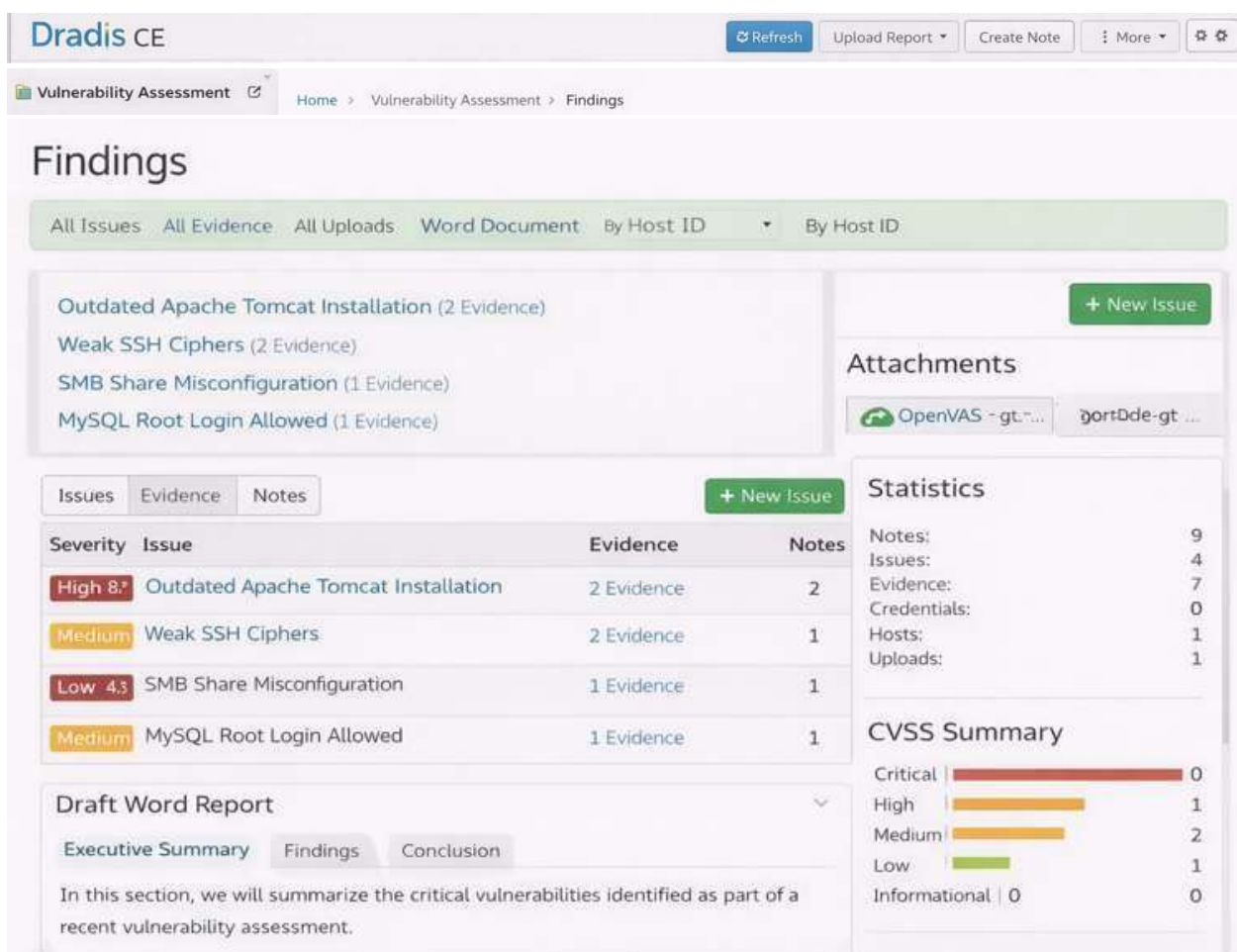


Figure 9: Dradis CE dashboard showing assessment project

CherryTree (Note-Taking for Technical Findings)

CherryTree was used as a hierarchical note-taking tool to document technical findings, commands executed, scan outputs, and screenshots during the assessment process.

- IP addresses and services
- Tool commands (Nmap, OpenVAS, Nikto)
- CVSS scores and risk levels
- Screenshots as evidence

CherryTree window showing:

- Target IP node
- Vulnerability sub-nodes



7. Conclusion & Key Learnings

This assessment provided hands-on experience in identifying and prioritizing security vulnerabilities using open-source tools. Challenges included configuring scanning tools and interpreting scan results, which were resolved through documentation and practice. The activity enhanced understanding of real-world vulnerability assessment and risk management processes.

References:

References

1. National Institute of Standards and Technology (NIST), *Framework for Improving Critical Infrastructure Cybersecurity*, NIST, USA.
2. Open Vulnerability Assessment System (OpenVAS), *OpenVAS Documentation*, Greenbone Security Assistant.
3. OWASP Foundation, *OWASP Top 10 – Web Application Security Risks*, OWASP.
4. OWASP Foundation, *OWASP Web Security Testing Guide (WSTG)*, OWASP.
5. Rapid7, *Metasploitable 3 – Vulnerable Virtual Machine*, GitHub Repository.
6. Kali Linux, *Official Kali Linux Documentation*, Offensive Security.
7. Nmap Project, *Nmap Network Scanning Guide*, Insecure.Org.
8. Rapid7, *Metasploit Framework Documentation*, Rapid7.
9. National Vulnerability Database (NVD), *Common Vulnerability Scoring System (CVSS) Calculator*, NIST.
10. Nikto Project, *Nikto Web Server Scanner Documentation*.
11. Elasticsearch, Logstash, and Kibana (ELK Stack), *Elastic Stack Documentation*, Elastic NV.
12. Dradis Framework, *Dradis Community Edition Documentation*.
13. CherryTree, *CherryTree Official Documentation*.
14. VulnHub, *Vulnerable Machines for Security Practice*.
15. CIS, *CIS Benchmarks for Security Configuration*, Center for Internet Security.